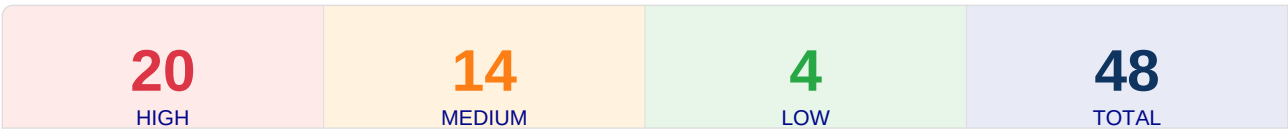


Cloud Security Analyzer

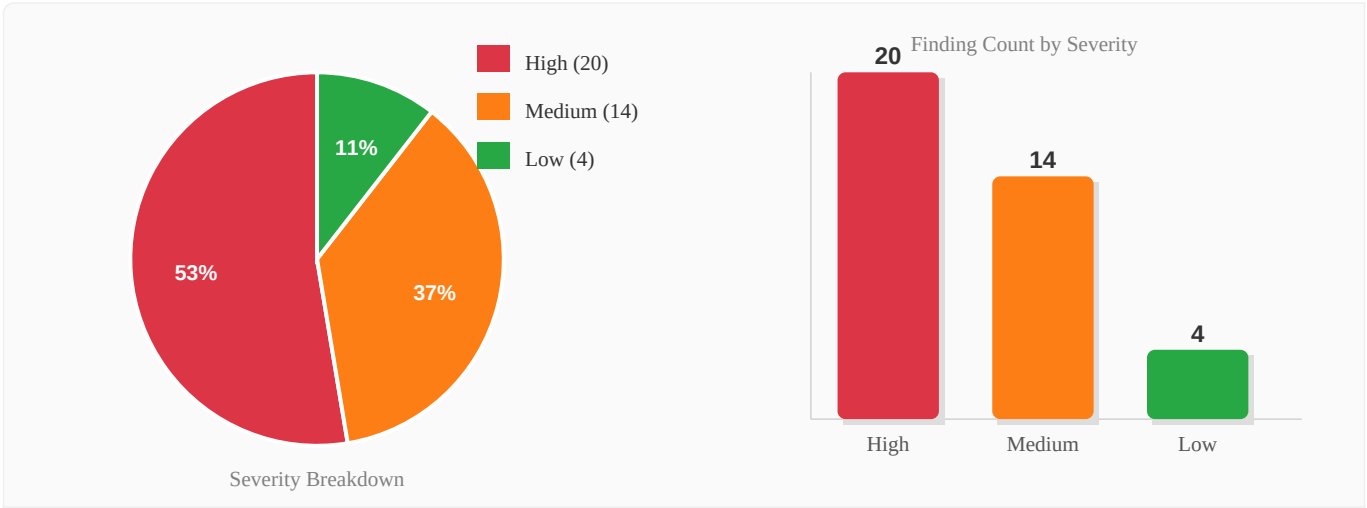
Security Assessment Report

Scan Name	Security Audit Mar 8, 2026
Organization	UOW
Analyst	Ashir Nasveer
Cloud Provider	AWS
Scan Date	2026-03-07 20:45:03 UTC
Status	Completed
Risk Score	0/100

Executive Summary



Severity Distribution — Visual Overview



Compliance Framework Coverage

Framework	Findings	Coverage
NIST: PR.DS-1	15	

PCI: 3.4	10	
NIST: PR.AC-5	9	
ISO: A.13.1.1	9	
ISO: A.8.2	9	
NIST: PR.AC-1	8	

Detailed Security Findings

#1. Root Account MFA Disabled

High

Resource	IAM / root
Compliance	CIS: 1.1 NIST: PR.AC-1 ISO: A.9.4.2 PCI: 8.3.1
Description	Root account has no MFA. Most privileged account in AWS.
Recommendation	Enable hardware MFA on root immediately.

#2. Root Account Has Active Access Keys

High

Resource	IAM / root
Compliance	CIS: 1.4 NIST: PR.AC-1 ISO: A.9.2.6 PCI: 8.2.4
Description	Programmatic access keys on root cannot be restricted by policies.
Recommendation	Delete all root access keys.

#3. No IAM Password Policy Configured

High

Resource	IAM / password-policy
Compliance	CIS: 1.5 NIST: PR.AC-1 ISO: A.9.4.3 PCI: 8.3.6
Description	No policy set. Default allows trivially weak passwords.
Recommendation	Configure: uppercase, numbers, symbols, 14+ chars, 90-day expiry.

#4. IAM User Without MFA: developer1

High

Resource	IAM / user/developer1
Compliance	CIS: 1.10 NIST: PR.AC-7 ISO: A.9.4.2 PCI: 8.4.2
Description	developer1 has no MFA. Single factor is weak.
Recommendation	Enable virtual or hardware MFA.

#5. Admin Policy Directly on User: dev2

High

Resource	IAM / user/dev2
Compliance	NIST: PR.AC-1 ISO: A.9 PCI: 7.1
Description	dev2 has AdministratorAccess directly. Violates least privilege.
Recommendation	Use roles/groups with scoped permissions.

#6. IAM Role Wildcard Trust: legacy-role

High

Resource	IAM / role/legacy-role
Compliance	NIST: PR.AC-1 ISO: A.9 PCI: 7.1
Description	Role can be assumed by anyone (*).
Recommendation	Restrict trust to specific principals.

#7. S3 Public Access Not Fully Blocked: my-public-data

High

Resource	S3 / my-public-data
Compliance	CIS: 2.1 NIST: PR.DS-1 ISO: A.8.2.3 PCI: 3.4
Description	Bucket missing Block Public Access settings.

Recommendation	Enable all 4 S3 Block Public Access settings.
-----------------------	---

#8. S3 Bucket Not Encrypted: app-assets-prod

High

Resource	S3 / app-assets-prod
Compliance	NIST: PR.DS-1 ISO: A.8.2 PCI: 3.5
Description	No SSE. Data at rest unprotected.
Recommendation	Enable AES-256 or KMS encryption.

#9. EBS Default Encryption Off: us-east-1

High

Resource	EC2 / account/us-east-1
Compliance	CIS: 2.2 NIST: PR.DS-1 ISO: A.8.2.3 PCI: 3.4
Description	New EBS volumes unencrypted by default.
Recommendation	Enable EBS default encryption in EC2 settings.

#10. Public EBS Snapshot: snap-0123abc

High

Resource	EC2 / snap-0123abc
Compliance	NIST: PR.DS-1 ISO: A.8.2 PCI: 3.4
Description	Snapshot is public. Anyone can clone your data.
Recommendation	Make snapshot private.

#11. Public AMI: ami-0xyz9876

High

Resource	EC2 / ami-0xyz9876
Compliance	NIST: PR.DS-1 ISO: A.8.2 PCI: 3.4
Description	Custom AMI is publicly accessible.
Recommendation	Make AMI private.

#12. Default SG Has Rules: default

High

Resource	SecurityGroup / sg-006 (default)
Compliance	CIS: 5.1 NIST: PR.AC-5 ISO: A.13.1.1 PCI: 1.3.2
Description	Default SG has rules. CIS: keep it empty. ■ ESCALATED: GuardDuty disabled — database attacks go undetected.
Recommendation	Remove all rules from default SG.

#13. CloudTrail Bucket May Be Public: ct-logs

High

Resource	CloudTrail / trail-main
Compliance	CIS: 3.1 NIST: DE.AE-1 ISO: A.12.4.1 PCI: 10.1
Description	Audit log S3 bucket not fully blocking public access!
Recommendation	Enable Block Public Access on log bucket.

#14. RDS Backup Retention 1 Day: analytics-rds

High

Resource	RDS / analytics-rds
Compliance	NIST: PR.DS-1 ISO: A.8.2 PCI: 3.5
Description	Only 1-day backup retention. ■ ESCALATED: GuardDuty disabled — database attacks go undetected.

Recommendation	Increase to 7+ days.
-----------------------	----------------------

#15. RDS Deletion Protection Off: dev-postgres

High

Resource	RDS / dev-postgres
Compliance	NIST: PR.IP-1 ISO: A.12.1 PCI: 6.4
Description	Can be accidentally deleted. ■ ESCALATED: GuardDuty disabled — database attacks go undetected.
Recommendation	Enable deletion protection.

#16. Lambda Deprecated Runtime: legacy-processor (python3.6)

High

Resource	Lambda / legacy-processor
Compliance	NIST: PR.IP-1 ISO: A.12.1 PCI: 6.4
Description	python3.6 is EOL. No security patches.
Recommendation	Upgrade to python3.12+.

#17. Lambda Env Vars May Have Secrets: api-handler

High

Resource	Lambda / api-handler
Compliance	NIST: PR.DS-1 ISO: A.8.2 PCI: 3.4
Description	Env vars DB_PASSWORD, API_KEY detected.
Recommendation	Use Secrets Manager instead.

#18. Lambda Publicly Invocable: pub-func

High

Resource	Lambda / pub-func
Compliance	NIST: PR.AC-1 ISO: A.9 PCI: 7.1
Description	Anyone can invoke this function.
Recommendation	Restrict resource policy.

#19. AWS Config Not Enabled: us-east-1

High

Resource	Config / region/us-east-1
Compliance	CIS: 3.1 NIST: DE.AE-1 ISO: A.12.4.1 PCI: 10.1
Description	Resource changes not tracked. Compliance drift undetected.
Recommendation	Enable AWS Config.

#20. GuardDuty Not Enabled: us-east-1

High

Resource	GuardDuty / region/us-east-1
Compliance	NIST: DE.CM-1 ISO: A.12.6 PCI: 11.5
Description	Threat detection inactive. Crypto mining, compromised instances undetected.
Recommendation	Enable GuardDuty in all regions.

#21. Stale Access Key (128d): ci-bot

Medium

Resource	IAM / user/ci-bot
Compliance	CIS: 1.4 NIST: PR.AC-1 ISO: A.9.2.6 PCI: 8.2.4
Description	Access key 128 days old. Rotate every 90 days.

Recommendation	Rotate keys. Use IAM roles instead.
-----------------------	-------------------------------------

#22. Unused Access Key (Never Used): old-svc

Medium

Resource	IAM / user/old-svc
Compliance	CIS: 1.4 NIST: PR.AC-1 ISO: A.9.2.6 PCI: 8.2.4
Description	Key created 95d ago, never used.
Recommendation	Delete unused keys.

#23. S3 HTTP Not Denied: logs-archive

Medium

Resource	S3 / logs-archive
Compliance	NIST: PR.DS-1 ISO: A.8.2 PCI: 3.4
Description	Bucket does not enforce HTTPS. MITM risk.
Recommendation	Add deny for aws:SecureTransport=false.

#24. S3 Versioning Disabled: backups

Medium

Resource	S3 / backups
Compliance	CIS: 2.1 NIST: PR.DS-1 ISO: A.8.2.3 PCI: 3.4
Description	Deletions permanent without versioning.
Recommendation	Enable versioning.

#25. IMDSv2 Not Enforced: i-0abc5678

Medium

Resource	EC2 / i-0abc5678
Compliance	NIST: PR.IP-1 ISO: A.12.1 PCI: 6.4
Description	IMDSv1 allows SSRF credential theft.
Recommendation	Set HttpTokens=required.

#26. Log Validation Disabled: trail-main

Medium

Resource	CloudTrail / trail-main
Compliance	CIS: 3.7 NIST: DE.AE-1 ISO: A.12.4.1 PCI: 10.5.2
Description	Log tampering undetectable.
Recommendation	Enable log file validation.

#27. Single-Region Trail: trail-main

Medium

Resource	CloudTrail / trail-main
Compliance	CIS: 3.1 NIST: DE.AE-1 ISO: A.12.4.1 PCI: 10.1
Description	Only us-east-1 covered. Other regions unlogged.
Recommendation	Enable multi-region.

#28. Trail Not KMS Encrypted: trail-main

Medium

Resource	CloudTrail / trail-main
Compliance	CIS: 3.7 NIST: DE.AE-1 ISO: A.12.4.1 PCI: 10.5.2
Description	Audit logs not encrypted at rest.

Recommendation	Associate KMS key.
-----------------------	--------------------

#29. VPC Flow Logs Disabled: vpc-0abc1234		Medium
Resource	VPC / vpc-0abc1234	
Compliance	CIS: 3.1 NIST: DE.AE-1 ISO: A.12.4.1 PCI: 10.1	
Description	Network traffic not logged. Lateral movement undetectable.	
Recommendation	Enable VPC Flow Logs.	

#30. Resources in Default VPC		Medium
Resource	VPC / vpc-default	
Compliance	NIST: PR.IP-1 ISO: A.12.1 PCI: 6.4	
Description	Instances in default VPC with permissive settings.	
Recommendation	Migrate to custom VPC.	

#31. NACL All Inbound Allowed: nacl-0abc		Medium
Resource	VPC / nacl-0abc	
Compliance	CIS: 5.1 NIST: PR.AC-5 ISO: A.13.1.1 PCI: 1.3.2	
Description	NACL allows all inbound. Only SGs protect instances.	
Recommendation	Add NACL deny rules for attack ports.	

#32. KMS Key Rotation Disabled: key-abc1234		Medium
Resource	KMS / key-abc1234...	
Compliance	NIST: PR.DS-1 ISO: A.8.2 PCI: 3.5	
Description	CMK has no auto-rotation. Older keys more vulnerable.	
Recommendation	Enable annual key rotation.	

#33. ELB Access Logs Disabled: prod-alb		Medium
Resource	ELB / prod-alb	
Compliance	NIST: DE.CM-1 ISO: A.12.6 PCI: 11.5	
Description	ALB not logging requests. Cannot audit traffic.	
Recommendation	Enable access logs to S3.	

#34. ELB HTTP Without HTTPS Redirect: prod-alb		Medium
Resource	ELB / prod-alb	
Compliance	NIST: PR.DS-1 ISO: A.8.2 PCI: 3.4	
Description	HTTP port 80 no redirect. Unencrypted traffic.	
Recommendation	Add HTTP→HTTPS redirect.	

#35. S3 Access Logging Disabled: temp-uploads		Low
Resource	S3 / temp-uploads	
Compliance	NIST: DE.CM-1 ISO: A.12.6 PCI: 11.5	
Description	No access logs.	

Recommendation	Enable server access logging.
----------------	-------------------------------

#36. S3 No Bucket Policy: static-site

Low

Resource	S3 / static-site
Compliance	NIST: PR.DS-1 ISO: A.8.2 PCI: 3.4
Description	No bucket policy.
Recommendation	Add HTTPS-enforcing bucket policy.

#37. Unattached EIP: 52.45.x.x

Low

Resource	EC2 / eip-x123
Compliance	NIST: PR.IP-1 ISO: A.12.1 PCI: 6.4
Description	EIP allocated, not attached. Unnecessary exposure.
Recommendation	Release or attach EIP.

#38. Auto Minor Upgrade Disabled: prod-mysql

Low

Resource	RDS / prod-mysql
Compliance	NIST: PR.IP-1 ISO: A.12.1 PCI: 6.4
Description	Security patches not auto-applied.
Recommendation	Enable AutoMinorVersionUpgrade.

#39. Unencrypted EBS Volume: vol-0abc1234

Critical

Resource	EC2 / vol-0abc1234
Compliance	CIS: 2.2 NIST: PR.DS-1 ISO: A.8.2.3 PCI: 3.4
Description	Volume attached to prod instance is unencrypted. ■ ESCALATED: Public snapshot exists AND volumes unencrypted — d
Recommendation	Encrypt via snapshot/restore.

#40. SG All Traffic Open: web-dmz

Critical

Resource	SecurityGroup / sg-001 (web-dmz)
Compliance	CIS: 4.1 NIST: PR.AC-5 ISO: A.13.1.1 PCI: 1.3
Description	SG allows ALL inbound from 0.0.0.0/0. Complete exposure.
Recommendation	Remove all-traffic rule.

#41. SG Exposes SSH(22): ssh-sg

Critical

Resource	SecurityGroup / sg-002 (ssh-sg)
Compliance	CIS: 4.1 NIST: PR.AC-5 ISO: A.13.1.1 PCI: 1.3
Description	Port 22 open to 0.0.0.0/0. Brute-force target. ■ ESCALATED: GuardDuty disabled — database attacks go undetected.
Recommendation	Restrict to known IPs or use SSM Session Manager.

#42. SG Exposes RDP(3389): rdp-sg

Critical

Resource	SecurityGroup / sg-003 (rdp-sg)
Compliance	CIS: 4.2 NIST: PR.AC-5 ISO: A.13.1.1 PCI: 1.3
Description	Port 3389 open to internet. Major attack vector. ■ ESCALATED: GuardDuty disabled — database attacks go undetected.

Recommendation	Close RDP. Use VPN or bastion.
----------------	--------------------------------

#43. SG Exposes MongoDB(27017): mongo-sg

Critical

Resource	SecurityGroup / sg-004 (mongo-sg)
Compliance	CIS: 5.1 NIST: PR.AC-5 ISO: A.13.1.1 PCI: 1.3.2
Description	MongoDB port open to internet. Critical data exposure. ■ ESCALATED: GuardDuty disabled — database attacks go under
Recommendation	Move to private subnet.

#44. SG Exposes Docker-API(2375): docker-sg

Critical

Resource	SecurityGroup / sg-005 (docker-sg)
Compliance	CIS: 5.1 NIST: PR.AC-5 ISO: A.13.1.1 PCI: 1.3.2
Description	Docker API exposed! Full host compromise possible.
Recommendation	Close port 2375 immediately.

#45. SG Exposes Redis(6379): app-sg

Critical

Resource	SecurityGroup / sg-007 (app-sg)
Compliance	CIS: 5.1 NIST: PR.AC-5 ISO: A.13.1.1 PCI: 1.3.2
Description	Redis port 6379 open to 0.0.0.0/0. ■ ESCALATED: GuardDuty disabled — database attacks go undetected.
Recommendation	Move Redis to private subnet.

#46. SG Exposes Elasticsearch(9200): elk-sg

Critical

Resource	SecurityGroup / sg-008 (elk)
Compliance	CIS: 5.1 NIST: PR.AC-5 ISO: A.13.1.1 PCI: 1.3.2
Description	Elasticsearch API open to internet. Unauthenticated access. ■ ESCALATED: GuardDuty disabled — database attacks go
Recommendation	Close 9200. Use VPC-only access.

#47. RDS Publicly Accessible: prod-mysql

Critical

Resource	RDS / prod-mysql
Compliance	CIS: 2.3 NIST: PR.DS-1 ISO: A.13.2 PCI: 1.3
Description	MySQL reachable from internet. ■ ESCALATED: GuardDuty disabled — database attacks go undetected.
Recommendation	Disable public access. Use private subnet.

#48. RDS Storage Not Encrypted: dev-postgres

Critical

Resource	RDS / dev-postgres
Compliance	CIS: 2.3 NIST: PR.DS-1 ISO: A.13.2 PCI: 1.3
Description	PostgreSQL storage unencrypted. ■ ESCALATED: GuardDuty disabled — database attacks go undetected.
Recommendation	Encrypt via snapshot/restore.